

Normativa ISO 27000 e ISO/IEC 27001

Norma ISO/IEC 27000

Los objetivos de la norma son:

- Asegurar la continuidad del negocio y de las operaciones de la organización.
- Reducir al mínimo los riesgos y los daños causados por una contingencia.
- Optimizar la inversión en tecnologías de la información.

Bajo tres pilares (CID / CIA):

1. Confidencialidad (*Confidentiality*).
2. Integridad (*Integrity*).
3. Disponibilidad (*Availability*).

Familia de las ISO 27000:

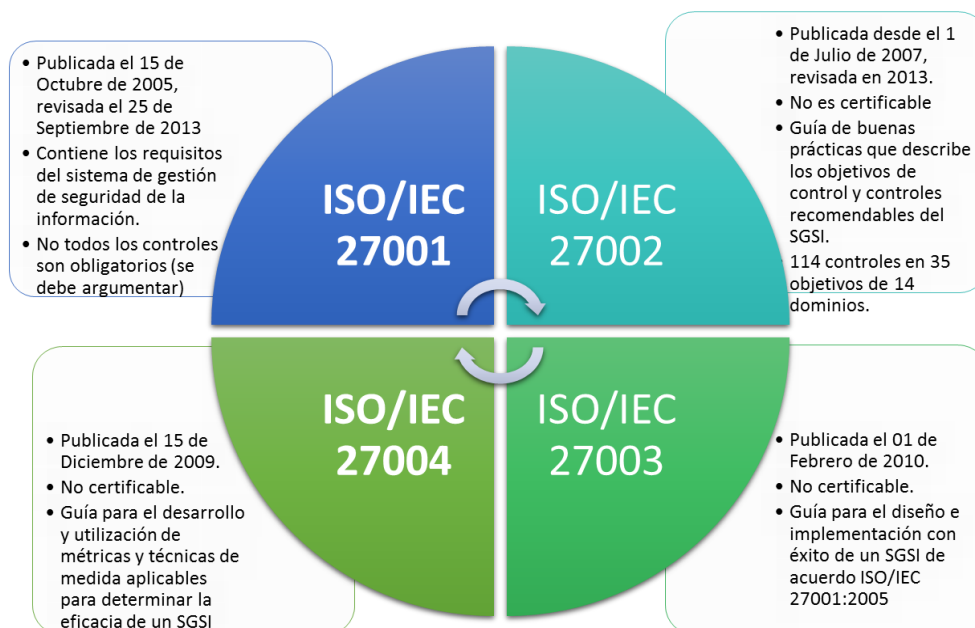


Figura 1: Familia ISO/IEC 27000 parte I. Fuente: elaboración propia.

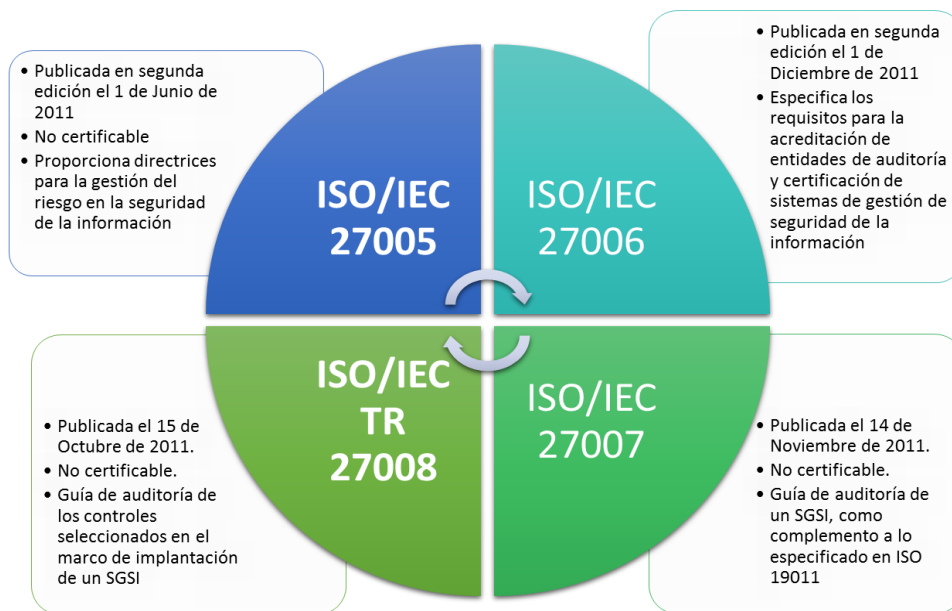


Figura 2: Familia ISO/IEC 27000 parte II. Fuente: elaboración propia.

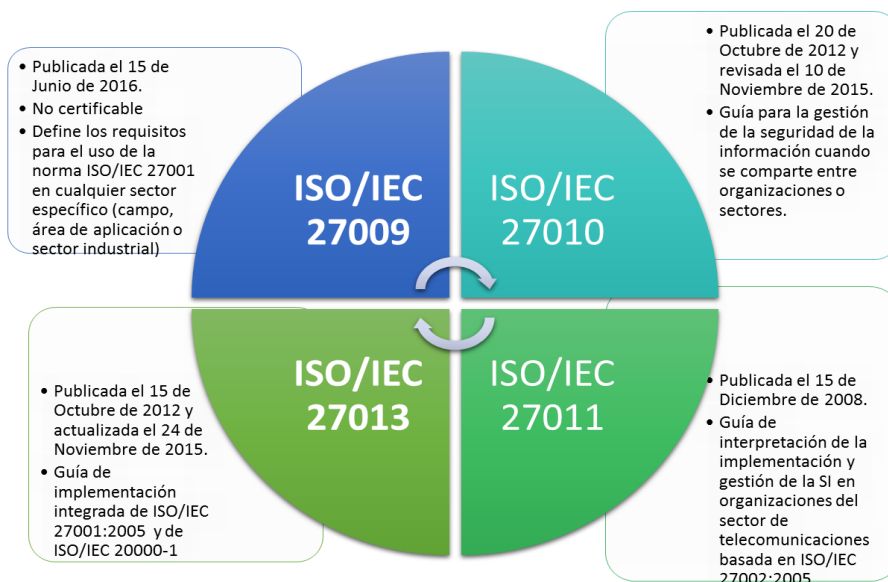


Figura 3: Familia ISO/IEC 27000 parte III. Fuente: elaboración propia.

ISO/IEC 27001 - ¿Qué es la Seguridad de la Información?

Durante el camino hacia la norma ISO/IEC 27000 es importante conocer la diferencia entre:

Seguridad Informática

Asegurar la información almacenada en medios informáticos. Se encarga de diseñar las normas, procedimientos y técnicas destinadas a conseguir un sistema de información seguro y confiable.

Seguridad de la Información

Asegurar los activos de la información de la organización. Reducir al mínimo los riesgos y los daños causados por una contingencia. Optimizar la inversión en tecnologías de seguridad. Contempla:

- Clasificación de la Información.
- Análisis y Gestión de Riesgos.
- Desarrollo del Marco Normativo.
- Implementación de controles.
- Medición de la eficacia de dichos controles.
- Mejora continua.

Dimensiones de la Seguridad de la Información:

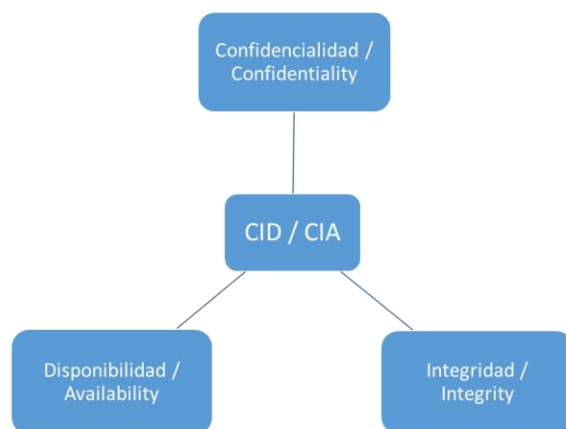


Figura 4: Pilares del SGSI. Fuente: elaboración propia.

1) Confidencialidad

La información es accedida sólo por personal autorizado y de manera autorizada. Procesa la información con un nivel de discreción. Busca que la información no sea revelada (*Disclosure*) por personas no autorizadas. Se transforma en privacidad al buscar proteger

la información de los individuos. Por ejemplo, cuando se habla de datos personales (Ley 25.326 – *Habeas Data*).

2) Integridad

La modificación de la información es realizada por personas autorizadas a través de métodos autorizados. Garantiza exactitud y fiabilidad de la información y sistemas. Previene accesos no autorizados que modifiquen la información (*Alteration*). Protege mecanismos de encriptación, a través de la función “*hash*”.

Consistencia:

- Interna: la información es consistente dentro del sistema informático.
- Externa: la información es consistente con “el mundo real”.

3) Disponibilidad

La información y los datos se encuentran disponibles para todo el personal autorizado cuando se necesite. Prevención de pérdidas (*Destruction*) de la información y/o recursos.

Asegurar:

- Confiabilidad y acceso a los datos y recursos para personas autorizadas.
- “Vuelta a la normalidad” después de una interrupción del servicio.
- Buena salud del software / hardware.

ISO/IEC 27001

Contiene una enumeración de requisitos a cumplir para la implementación de un SGSI y se puede certificar. Asimismo, se encuentra basada en el modelo PDCA y puede ser aplicada a una Empresa, a un área o a un proceso específico.

Para establecer un modelo SGSI o “modelo de gestión”, se puede iniciar siguiendo:

1) Definir una Política de Seguridad de la Información

- Mantenimiento y mejora del SGSI.
- Planificar y adoptar las acciones preventivas y correctivas.

2) Definir un enfoque Sistemático de valoración de riesgo

- Implementar plan el SGSI.

- Implementar los procesos, procedimientos y controles.
- Formación y concientización.

3) Declaración de Aplicabilidad (SOA)

- Documento que contiene la selección de controles y cómo se van a implementar, programas y costos; es un plan de acción.

Estructura y contenido de la norma:

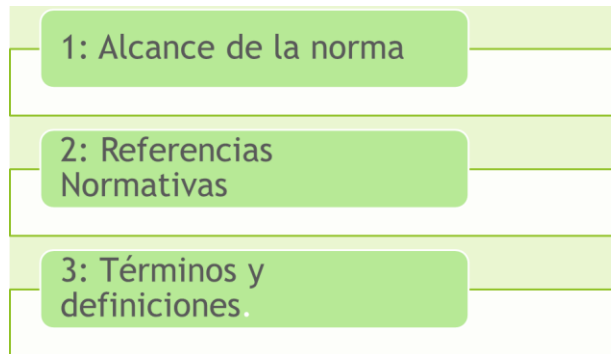


Figura 5: Estructura ISO/IEC 27001 - Parte I. Fuente: elaboración propia.

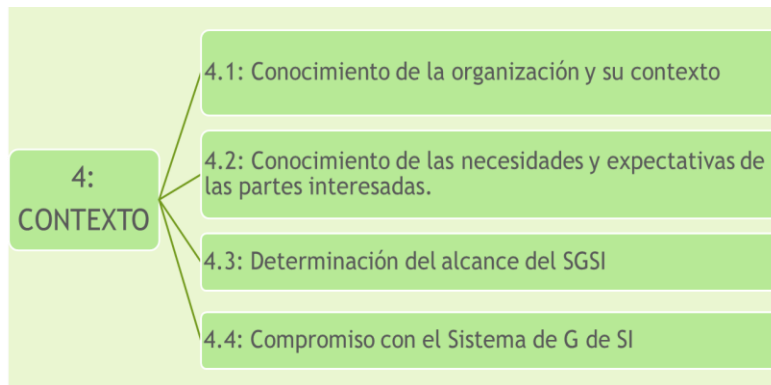


Figura 6: Estructura ISO/IEC 27001 Parte II. Fuente: elaboración propia.



Figura 7: Estructura ISO/IEC 27001 Parte III. Fuente: elaboración propia.

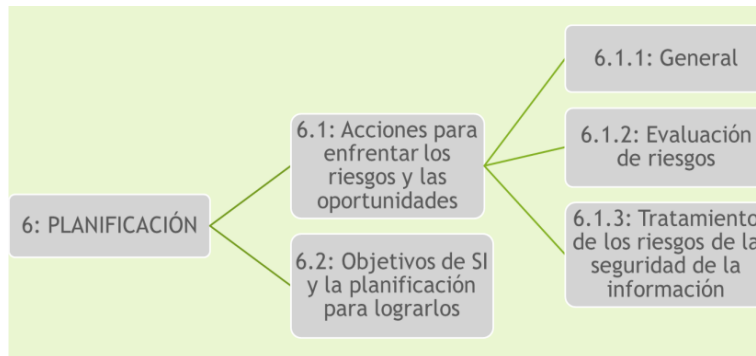


Figura 8: Estructura ISO/IEC 27001 Parte IV. Fuente: elaboración propia.

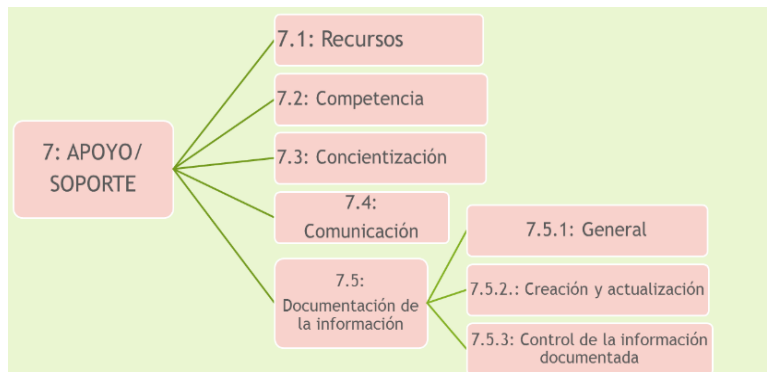


Figura 9: Estructura ISO/IEC 27001 Parte V. Fuente: elaboración propia.

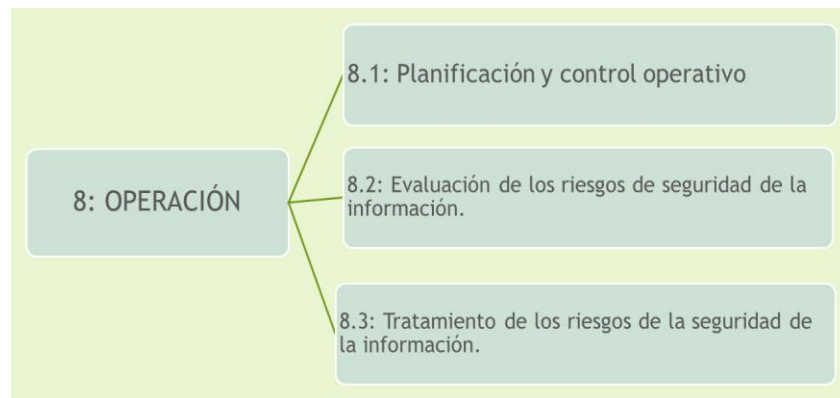


Figura 10: Estructura ISO/IEC 27001 Parte VI. Fuente: elaboración propia.

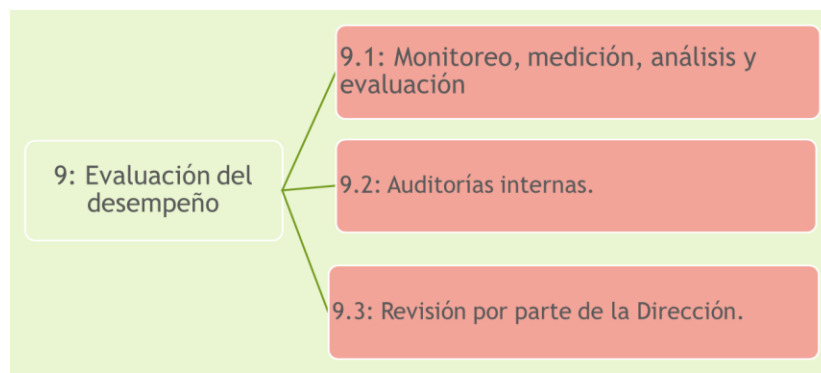


Figura 11: Estructura ISO/IEC 27001 Parte VII. Fuente: elaboración propia.

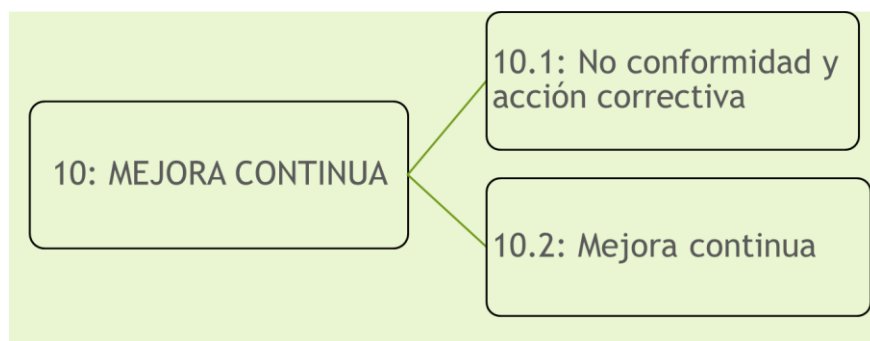


Figura 12: Estructura ISO/IEC 27001 Parte VIII. Fuente: elaboración propia.

Operación de un SGSI

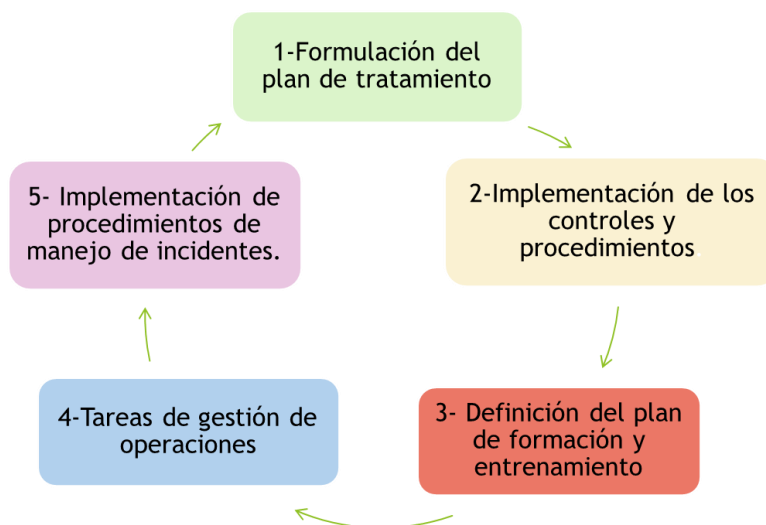


Figura 13: SGSI. Fuente: elaboración propia.

Referencias

IRAM ISO/IEC 2700:2013 - Sistemas de gestión de la seguridad de la información

- En español: <http://www.iso27000.es/>
- En inglés: <http://www.iso27001security.com/>

ISO/IEC 27000 en iso.org: <https://www.iso.org/obp/ui/#iso:std:iso-iec:27000:ed-3:v1:en>